Incident Response Planning Assignment

GRC105 – Incident Management and Business Continuity | Week 20

Student details	Information
Student name	Amina Gebi
Student ID	2025/GCR/12750
Official student email	gcr2512750@students.icdfa.edu.ng
Assessment type	Individual assignment – all six tasks
Word count	Approx. 10,909 words (including tables; excluding references and front matter)
Submission date	19/10/2026

Framework approach

This report uses the four teaching stages presented in the ICDFA Week 20 slides: preparation; detection and analysis; containment, eradication and recovery; and post-incident activity. These are the teaching stages used to organise this assignment. NIST SP 800-61 Rev. 3 aligns incident response with the CSF 2.0 functions Detect, Respond and Recover, while Govern, Identify and Protect support preparation. Lessons learned feed continuous improvement across the functions (ICDFA, n.d., slides 6–16; Nelson et al., 2025).

Authorship and use of assistance

I used AI assistance to help organise and edit parts of this assignment. I reviewed the content, checked it against the supplied scenario and teaching materials, and take responsibility for the final analysis and decisions. This acknowledgement should be retained or amended to match the course's AI-use policy and the assistance actually used.

Case reminder

Northbridge Skills Institute is fictional. The incident is taken over at 08:45 WAT on Monday (Day 0). Use E01–E08 when referring to supplied observations. Distinguish confirmed facts from hypotheses, and mark additional assumptions clearly.

Contents

Task 1 – Incident classification and initial assessment (15 marks)

Task 2 – Incident response plan and team responsibilities (20 marks)

Task 3 – Response playbook and evidence preservation (25 marks)

Task 4 – Communication and escalation (10 marks)

Task 5 – Tabletop exercise and improvement plan (15 marks)

Task 6 – Case study analysis and critical reflection (10 marks)

References

Task 1. Incident classification and initial assessment

1.1 Incident summary and initial classification

By 08:45 WAT, Northbridge Skills Institute was dealing with a suspected ransomware incident that had disrupted its operations. The concern began after a finance officer opened an unexpected payroll attachment on FIN-PC07 the previous day (E01). During the early hours of Day 0, there were unusual sign-ins to the finance officer's Microsoft 365 account and unusual remote administrator logins using the svc_backup account (E02 and E03). A 1.2 GB upload to unfamiliar cloud storage was also recorded, although the contents of the transfer are unknown (E04).

At 08:30, mass file changes were reported on FIN-PC07, while FS01 contained locked files and a ransom note (E06). The learning portal was still loading, but learners could not open materials or submit their assessments (E07). The incident also affected the response team's ability to coordinate because the contact list stored on FS01 was inaccessible (E08).

I would classify this as a suspected ransomware incident because the locked files and ransom note provide strong evidence of ransomware activity. However, the full extent of the compromise is still unknown. The evidence does not yet confirm whether the svc_backup account was compromised, whether the backup repository is safe, or whether information was stolen. The immediate operational consequences are the disruption of learning activities and the risk that shared files, backups and other systems may also be affected. With an examination scheduled for 11:00, the institute must contain the incident, investigate its scope and determine whether services can be restored safely.

1.2 Evidence timeline

Evidence ID / time (WAT)	Confirmed observation from the brief	Working hypothesis (labelled)	Unresolved question / next check
E01 – Day −1, 16:40	A finance officer opened an unexpected payroll attachment on FIN-PC07. The evidence does not confirm whether the attachment executed code.	The attachment may have been used to introduce malware into the workstation. However, opening it does not, by itself, prove that the system was infected.	Did the attachment execute anything, and is there evidence of a malicious process or file on FIN-PC07?
E02 – Day 0, 01:15	The finance officer's Microsoft 365 account recorded a sign-in from an unfamiliar IP address and a new device. It is not yet known whether the user was involved or whether MFA was used.	The account may have been accessed by an unauthorized person. However, the unfamiliar sign-in alone does not confirm that the account was compromised or that any malicious activity occurred.	Was the sign-in legitimate or unauthorised, was MFA used, and what activities, if any, followed the sign-in?

E03 – Day 0, 01:35	The svc_backup account recorded remote administrator logins to FS01 and BAK01 outside its usual schedule. The reason for these logins is unknown.	The account may have been used by an unauthorized person to access the file server and backup repository. However, the unusual timing alone does not prove that the access was malicious or that any damage occurred.	Who or what initiated the logins, whether the activity was authorized, why the account was used outside its usual schedule, and what actions were performed on both systems?
E04 – Day 0, 01:50	[A 1.2 GB upload was recorded from FIN-PC07 to unfamiliar cloud storage over HTTPS. The contents of the transfer are unknown.	The upload may indicate possible data theft or unauthorized data transfer. However, there is not enough evidence to conclude that the activity was malicious because the contents and purpose of the transfer have not been established.	The team needs to establish what data was transferred, where it was sent, who controlled the destination, and whether the transfer was authorized.
E05 – Day 0, 02:00	The backup console reported that the FS01 and LMS01 backup jobs completed successfully. However, their recoverability and freedom from compromise have not been established.	Although the backup jobs completed successfully, the backed-up data may already have been compromised if malicious activity occurred before the backups were taken. The backups may also be unusable if restoration fails. Neither possibility has yet been confirmed.	The team needs to establish when the backups were taken, whether the data is complete and free from compromise, and whether the backups can be restored successfully.
E06 – Day 0, 08:30	Mass file changes were reported on FIN-PC07, while FS01 shares contained .locked files and a ransom note. The malware family has not been confirmed.	The evidence strongly suggests ransomware activity. Files may have been encrypted, making them inaccessible to users. However, the full extent of the attack and the method used to gain access have not yet been established.	The team needs to establish which systems and files have been affected, how the ransomware gained access and spread, whether the attack is still ongoing, and how the affected data can be recovered safely and made available to users.
E07 – Day 0, 08:40	The learning portal login page loads, but learners cannot open learning materials or submit assessments. The portal depends on files stored on FS01, and the full extent of the impact on LMS01 has not been established.	The ransomware activity affecting FS01 may have made files required by the learning portal inaccessible. This could explain why learners can log in but cannot access materials	The team needs to establish whether the disruption is caused by the affected files on FS01, whether LMS01 itself has been compromised, and which services and learning activities can be safely restored.

		or submit assessments. However, the precise cause of the LMS disruption still needs to be confirmed.	
E08 – Day 0, 08:45	The contact list stored on FS01 is inaccessible. Staff phones are available, but the trustworthiness of corporate email has not been established.	The contact list may have become inaccessible because of the ransomware activity affecting FS01. Corporate email may also be unsafe to rely on until the team establishes whether the relevant accounts and systems can be trusted.	The team needs to determine whether the contact list is inaccessible because its files were encrypted, whether corporate email accounts or systems have been compromised, and which alternative communication channels can be used safely.

1.3 Alternative explanations for ambiguous events

Ambiguous event	Plausible explanation A	Plausible explanation B	Evidence that would distinguish them
E01: Payroll attachment	The unexpected payroll attachment may have contained malicious code that executed when the finance officer opened it, providing an entry point for the attack.	The attachment may have been a legitimate document, or it may have been opened without any malicious code executing.	Examine the email and attachment, endpoint security alerts, process execution logs and file activity on FIN-PC07. Interview the finance officer to establish what happened when the attachment was opened.
E02/E03: Unusual logons	An unauthorised person may have accessed the finance officer's Microsoft 365 account and misused the `svc_backup` account to access FS01 and BAK01.	The finance officer may have legitimately used a new device or network, while the `svc_backup` logons may have resulted from an authorised administrative or backup activity outside the usual schedule.	Review Microsoft 365 sign-in, audit and MFA records, Windows authentication logs, source devices and IP addresses, and administrator activity on FS01 and BAK01. Interview the finance officer and relevant IT staff to verify whether the activity was authorised.
E04: 1.2 GB upload	The upload may represent unauthorised transfer of confidential organisational data to an external destination.	An authorised user or application may have transferred files to a cloud service for a legitimate business purpose.	Review network and endpoint logs, identify the cloud destination and determine which files were transferred, where possible. Check whether the transfer was approved and confirm its purpose with the relevant user or system owner.

1.4 Incident type and initial severity

Incident type

Based on the evidence available, I would classify this as a suspected ransomware incident. On FIN-PC07, there were reports of mass file changes, while locked files and a ransom note were found on FS01 (E06). These findings strongly suggest that ransomware activity has occurred. There are also concerns about the unusual Microsoft 365 sign-in (E02), the administrator logins using the `svc_backup` account (E03), and the 1.2 GB upload to unfamiliar cloud storage (E04). However, we cannot yet confirm whether all these events are connected, how the attacker gained access, or whether any sensitive information was stolen. Further investigation is needed to establish what happened and how far the incident has spread.

Severity classification criteria

Severity	Criteria
Critical	An incident that causes severe disruption to essential services, affects a large part of the organisation, or creates a serious risk to important data and the organisation's ability to recover.
High	A serious incident that disrupts important services, affects several systems, or raises significant concerns about data security and the safety of backups.
Medium	An incident with limited impact that affects a small number of systems but does not seriously disrupt essential services.
Low	A minor incident with little or no disruption to normal operations and no clear indication of wider compromise.

Initial severity and justification

I would classify this incident as High severity at this stage. The discovery of locked files and a ransom note on FS01, together with the mass file changes on FIN-PC07 (E06), indicates a serious security problem. The learning portal has also been affected, as learners cannot open their materials or submit assessments (E07). This is particularly concerning because an examination involving 100 learners is scheduled for 11:00.

Another concern is the unusual activity involving the `svc_backup` account, which has administrator access to both FS01 and BAK01 (E03). The team has also not confirmed whether the available backups are safe to use (E05). In addition, the 1.2 GB upload to unfamiliar cloud storage raises the possibility that information may have been transferred without authorisation (E04), although this has not been established.

I consider High severity appropriate because important services are already affected and there are still unanswered questions about the extent of the incident. The classification should be reviewed as the investigation progresses. If the team discovers that the attack has spread further, that sensitive information has been seriously compromised, or that the organisation cannot recover essential services safely, the incident may need to be escalated to Critical.

1.5 Asset and CIA impact assessment

Based on the available evidence, FIN-PC07 and FS01 are the systems with the clearest signs of impact. LMS01 is experiencing a service disruption, while BAK01 is potentially at risk because of the unusual administrator logins involving the `svc_backup` account. The full extent of the incident is still unknown, so further investigation is needed to determine which other systems and data may have been affected.

Asset	Confidentiality	Integrity	Availability
FIN-PC07 – Finance workstation	The 1.2 GB upload to unfamiliar cloud storage raises concerns that information may have left the organisation without authorisation (E04). The contents of the upload are unknown.	The mass file changes suggest that files may have been altered or encrypted (E06).	The reported file changes may have made some files inaccessible. The full extent of the disruption needs to be checked (E06).
FS01 – Shared file server	Unusual administrator logins and the possibility of data exposure raise concerns about unauthorised access (E03, E04).	The `.locked` files and ransom note indicate likely ransomware-related changes to shared files (E06).	Some shared files are inaccessible, and the contact list stored on FS01 cannot be accessed (E06, E08).
LMS01 – Learning portal	There is not enough evidence to establish whether learner information has been exposed.	The integrity of the portal and its learning materials needs to be checked because the portal depends on files stored on FS01.	Learners cannot open materials or submit assessments, even though the login page loads (E07).
BAK01 – Backup repository	The unusual administrator logins raise concerns about possible unauthorised access (E03).	The team has not established whether the backups are free from compromise or whether their contents can be trusted (E05).	The team has not confirmed whether the backups can be restored successfully. The last disconnected backup was made on Day −3 at 17:00.

The Microsoft 365 account should also be investigated because the unusual sign-in may indicate unauthorised access (E02). However, the available evidence does not establish that the account was compromised.

Response priorities

My first priority would be to contain the incident and prevent further damage. FIN-PC07 should be isolated because of the reported mass file changes, while the suspicious `svc_backup` account should be restricted through an authorised procedure. The team should also investigate FS01 and BAK01 to determine whether the attack has spread or the backup environment has been affected. Relevant logs and other evidence should be preserved without unnecessarily delaying urgent containment.

The next priority is to establish whether the backups are safe and usable. A successful backup job does not guarantee that the data is clean, complete or recoverable. The team should assess the available backups and identify a suitable clean recovery point before attempting restoration.

The 11:00 examination involving 100 learners is also an urgent business concern. The team should assess whether the learning portal can be restored safely in time. If this is not possible, management should be informed promptly so that alternative arrangements, including postponing the examination, can be considered.

Finally, the team should investigate the 1.2 GB upload to determine whether sensitive information was transferred without authorisation. This could affect the severity of the incident and may require further legal and privacy assessment. The severity should be reviewed as new findings emerge.

1.6 Priority investigation questions

The following questions should be investigated first because their answers will help the team understand how the incident started, how far it has spread, and what is required for a safe recovery.

Priority investigation question	Evidence or checks required	How the findings could affect severity or scope
1. Did the payroll attachment provide the attacker with access to FIN-PC07?	Examine the original email and attachment, endpoint security alerts, process execution logs and other activity recorded on FIN-PC07. Interview the finance officer about what happened after opening the attachment.	If the attachment is linked to malicious activity, it could help establish the likely entry point and guide the search for other affected systems. If no link is found, the team must investigate other possible entry points.
2. Was the `svc_backup` account used without authorisation, and	Review Windows authentication logs, remote administrator sessions, file activity and backup logs. Check	Evidence of unauthorised activity on BAK01 would raise concerns about the safety of the backups and could make

were FS01 or BAK01 affected?	the source of the logins and interview the IT staff responsible for backup operations.	recovery more difficult. Evidence that the account was used to access additional systems could also expand the scope of the incident.
3. What was transferred in the 1.2 GB upload, and was the transfer authorised?	Review available network and endpoint logs, identify the cloud storage destination, and examine transfer records to establish what data was sent, where possible. Confirm the activity with the relevant user or system owner.	If sensitive information was transferred without authorisation, the incident could have a wider impact and require further legal and privacy assessment. If the transfer was legitimate, this concern could be reduced, provided the evidence supports that conclusion.
4. Which backups are safe and can be restored successfully?	Review backup logs and available recovery points. Assess the backup repository for signs of compromise and test a suitable backup in a controlled environment before using it to restore production services.	If a clean, complete and recoverable backup is available, the team may be able to restore services more quickly. If the backups are compromised or unusable, the disruption may last longer and the incident's operational impact may increase.

These questions should be investigated as a priority because they address the possible entry point, suspicious account activity, potential data exposure and the ability to recover affected services. The team should revise its severity and scope assessment as reliable findings become available, rather than treating initial suspicions as confirmed facts.

Task 2. Incident response plan and team responsibilities

2.1 Policy and plan outline

Mission

The purpose of Northbridge Skills Institute's Incident Response Plan is to ensure that cybersecurity incidents are handled in an organised and timely manner, with the aim of limiting damage, protecting information and restoring essential services safely.

Objectives

The plan aims to detect incidents early, contain threats, preserve evidence, investigate affected systems, restore services safely and keep management and other relevant stakeholders informed. It also helps the institute learn from incidents and improve its security arrangements.

Scope

The plan covers the institute's workstations, file servers, learning portal, backup systems, Microsoft 365 accounts, network services and the information stored on these systems. It applies to staff and IT personnel involved in preventing, identifying, investigating or responding to cybersecurity incidents, including ransomware, unauthorised access and suspected data theft.

Incident declaration and activation

The plan should be activated when there is credible evidence of a cybersecurity incident that could affect the confidentiality, integrity or availability of the institute's systems or information. The incident response lead should coordinate the initial assessment and inform management. Where there is evidence of active ransomware, unauthorised administrator access or significant service disruption, containment should begin promptly rather than waiting for every detail to be confirmed.

Escalation and authority

The incident response lead should assess the initial severity and escalate serious incidents to senior management. The lead may direct urgent containment actions within the authority granted by the institute's procedures. IT operations should isolate affected devices or systems when authorised, while actions that could significantly disrupt essential services should be coordinated with the relevant system owner and management where time permits. Urgent action to prevent further damage should not be unnecessarily delayed.

Decisions about restoring services should be made by the designated restoration approver, based on technical advice from the response team and confirmation that the proposed recovery is sufficiently safe.

Documentation and review

The team should maintain an incident log recording the time of each event, evidence collected, actions taken, decisions made, approvals, people involved and communication with stakeholders. Evidence must be protected from unauthorised access, and its handling should be documented.

After the incident, the team should review what happened, identify gaps in the response and assign improvements to named owners. The plan should also be reviewed at least annually and after any major incident, significant system change or exercise.

Connection with business continuity

Incident response focuses on containing and investigating the security incident, while business continuity focuses on keeping essential activities running during the disruption. At Northbridge, this means responding to the ransomware while also deciding how to manage the examination scheduled for 11:00. If the learning portal cannot be restored safely in time, management should consider alternative examination arrangements rather than risk restoring compromised systems simply to meet the deadline.

2.2 Computer Security Incident Response Team (CSIRT)

Northbridge does not have a large IT or security department, so the response team should be built around the staff already available, with external specialists brought in when necessary.

The institute should establish a Computer Security Incident Response Team (CSIRT) with clearly defined responsibilities. Since it has only three IT staff and one security analyst, some team members may perform more than one role. However, important decisions and responsibilities must still be assigned clearly.

Role	Main responsibility
1. Incident Response Lead	Coordinates the response, assigns tasks, maintains the incident log and escalates important decisions to management.
2. Security Analyst	Reviews security alerts and logs, identifies suspicious activity, assesses the likely scope of the incident and recommends containment actions.
3. Forensics Specialist	Collects and examines digital evidence, maintains records of evidence handling and helps determine how the incident occurred. If no internal specialist is available, an external expert should be engaged.
4. IT Operations / System Owner	Manages affected workstations, servers, the learning portal and backups. Carries out approved isolation, technical checks and recovery activities.
5. Legal / Privacy Adviser	Advises on legal obligations, possible personal data exposure, record keeping and whether notifications to relevant authorities or affected individuals may be required.
6. Communications Lead	Prepares and coordinates updates to staff, learners, management and other relevant stakeholders using approved communication channels.
7. Management / Business Continuity Lead	Makes business-level decisions, approves significant service disruption or alternative arrangements, and ensures essential activities continue where possible.

Obtaining additional support

The institute should not assume that its small team can handle every incident alone. If the incident extends beyond its technical capacity, the Incident Response Lead should request external incident response or forensic support. Additional assistance may also be needed from the learning portal provider, Microsoft 365 support, backup service providers or legal and privacy specialists.

The institute should identify these contacts in advance, agree how support will be requested and ensure that external parties can be reached through trusted communication channels during an incident.

2.3 RACI matrix

RACI matrix

RACI clarifies who performs each activity and who is answerable for ensuring that it is completed.

- R — Responsible: Performs the work.
- A — Accountable: Owns the outcome and makes sure the activity is completed. Each activity below has exactly one accountable role.
- C — Consulted: Provides advice or specialist input.
- I — Informed: Receives updates about the activity or its outcome.

The role abbreviations used in the table are:

IRL — Incident Response Lead

Coordinates the overall response.

SA — Security Analyst

Analyses security alerts and activity.

FS — Forensics Specialist

Collects and examines evidence.

IT — IT Operations / System Owner

Manages systems, containment and technical recovery.

LP — Legal / Privacy Adviser

Advises on legal and privacy matters.

COM — Communications Lead

Coordinates approved stakeholder messages.

MBC — Management / Business Continuity Lead

Owns major business-impact and continuity decisions.

Activity	IRL	SA	FS	IT	LP	COM	MBC
Detection and initial reporting	A	R	I	R	I	I	I
Incident analysis and scope assessment	A	R	R	C	C	I	I
Containment of affected systems	A	R	C	R	I	I	C
Evidence collection and handling	A	C	R	R	C	I	I
Stakeholder communication	C	I	I	C	C	R	A
Assessment of reporting obligations	C	C	C	I	R	C	A
Restoration approval	C	C	C	R	C	I	A
Incident closure and post-incident review	R	C	C	C	C	C	A

The Incident Response Lead coordinates the technical response and makes sure activities are carried out in an organised manner. Management remains accountable for major business decisions, including stakeholder communication approval, the assessment of reporting obligations, restoration approval and formal closure. The Legal / Privacy Adviser provides specialist advice on reporting obligations, while IT Operations carries out approved technical work.

For each activity, one role is designated Accountable, and at least one role is Responsible. The assignments should be confirmed by management before the plan is formally adopted.

2.4 Preparation and readiness checklist

The Northbridge incident shows why preparation matters. The team needs to be able to contact the right people, investigate suspicious activity, preserve evidence and restore systems without relying on assumptions. These measures are consistent with ransomware readiness guidance that emphasises preparation, secure backups and tested response arrangements (CISA et al., 2023; Nelson et al., 2025).

The following improvements should be completed to help the institute respond more effectively to future incidents.

Improvement	Owner	Resources needed	How readiness will be checked
1. Improve backup readiness	IT Operations / System Owner	Protected backup storage, a disconnected or immutable backup copy, restoration	Carry out scheduled restoration tests and record whether files are complete,

		procedures and a test environment.	usable and free from signs of compromise.
2. Maintain an accessible incident contact list	Incident Response Lead	An up-to-date printed contact list and a securely stored offline copy containing staff, management, service provider and emergency contacts.	Test the list periodically to confirm that contacts are correct and reachable without relying on FS01 or corporate email.
3. Prepare incident investigation tools	Security Analyst	Suitable endpoint monitoring, centralised logs, secure evidence storage and tools for examining suspicious files and account activity.	Run a simulated incident and confirm that the team can access relevant logs, identify suspicious activity and preserve evidence.
4. Establish secure alternative communication channels	Communications Lead	An approved secure communication method, staff phone contacts and procedures for verifying important messages.	Test the alternative channels and confirm that the response team can coordinate if corporate email is unavailable or cannot be trusted.
5. Train and exercise the response team	Incident Response Lead	Staff time, a tabletop exercise scenario, an incident log template and basic incident response procedures.	Conduct regular exercises, record decisions and response times, and track identified gaps until they are addressed.

These improvements should be assigned target dates and reviewed by management. Any gaps identified during testing should have a named owner and a follow-up date to confirm that the problem has been resolved.

Task 3. Response playbook and evidence preservation

3.1 Incident response playbook

The incident response lead takes control at 08:45 WAT on Day 0. The first priority is to limit further damage while preserving evidence wherever doing so does not delay necessary containment. The team must also assess the risk to the examination scheduled for 11:00. The playbook follows the containment, eradication and recovery stage in the teaching deck (ICDFA, n.d., slide 11).

A. First 60 minutes: 08:45–09:45 WAT

The times below are the proposed response schedule. If a more urgent threat is identified, the team should act immediately rather than wait for the next scheduled step.

Time / stage	Action	Owner	Required approval	Evidence to retain	Completion check
08:45–08:50 — Take control	Declare a suspected ransomware incident, assign the incident lead and open an incident log. Notify management using a trusted channel.	Incident Response Lead	Incident declaration under the institute's procedure	Incident log, declaration time and initial severity	Lead is identified, incident ID is recorded and key staff are notified.
08:50–08:55 — Contain FIN-PC07	Isolate FIN-PC07 from the network to limit further malicious activity. If practical, capture useful volatile evidence first, but do not delay urgent isolation where damage may continue.	IT Operations	Incident lead or authorised emergency procedure	Isolation time, device details, alerts and any evidence not captured	The workstation is disconnected and the action is documented.
08:55–09:00 — Protect accounts	Restrict the suspicious `svc_backup` account and investigate the finance officer's Microsoft 365 account. Preserve relevant authentication records.	Security Analyst and IT Operations	Incident lead; emergency account controls under policy	Sign-in records, account changes, approval and action times	Risky access is restricted, and essential backup activity is not resumed without a safe alternative.

09:00–09:05 — Protect backups	Restrict unnecessary access to BAK01 and prevent backup jobs or administrative activity from overwriting useful recovery points. Avoid deleting backups or making unplanned changes.	IT Operations	Incident lead or authorised system owner	Backup console records, access logs and configuration changes	Backup access is controlled and available recovery points are protected.
09:05–09:10 — Assess FS01	Assess the affected shared server and restrict access or isolate it if active compromise or further damage is suspected. Coordinate with the incident lead to manage the impact on dependent services.	Security Analyst and IT Operations	Incident lead or emergency containment procedure	Windows logs, file-change records, ransom note and relevant alerts	The team has documented the server's condition and taken appropriate containment action.
09:10–09:15 — Preserve evidence	Identify the most important logs and artefacts from FIN-PC07, FS01, Microsoft 365 and the backup environment. Begin documented evidence collection where safe and practical.	Forensics Specialist or designated trained staff	Incident lead; follow evidence-handling procedures	Original logs, relevant files, collection records and custody entries	Each collected item has an ID, source, collector and storage location.
09:15–09:20 — Investigate the upload	Investigate the 1.2 GB HTTPS upload, identify the destination and establish what information may have left FIN-PC07. Restrict suspicious outbound access where appropriate.	Security Analyst	Incident lead; network or system owner as required	Network records, endpoint logs, destination details and relevant transfer records	The destination and available details of the transfer are documented; unknowns remain clearly labelled.
09:20–09:30 — Check wider compromise	Review related endpoint alerts, sign-ins, administrator sessions, file changes and activity on	Security Analyst and IT Operations	Incident lead	Relevant security alerts, authentication logs and system findings	An initial list of affected, potentially affected and not-

	LMS01 and BAK01. Look for evidence of lateral movement or additional affected accounts and systems.				yet-assessed assets is recorded.
09:30–09:35 — Assess business impact	Confirm the effect on learning materials, assessment submissions, staff operations and the 11:00 examination. Inform management of what is known and what remains uncertain.	Management / Business Continuity Lead	Management under business continuity arrangements	Impact assessment and decision log	Management has the facts needed to consider alternative examination arrangements.
09:35–09:40 — Assess recovery options	Review available backup records and the last disconnected backup. Do not restore an unverified backup to production. Identify possible clean recovery points for controlled testing.	IT Operations and Security Analyst	Incident lead for testing; designated approver for production restoration	Backup logs, recovery-point details and test results when available	Candidate backups are identified, with their safety and recoverability marked as confirmed, rejected or still under assessment.
09:40–09:45 — Set next actions	Update severity, assign investigation tasks, agree the next management update and record any decisions about service continuity.	Incident Response Lead	Management for major business decisions	Updated incident log, action owners and decision records	Immediate actions have owners and deadlines, and the next review time is agreed.

B. Remainder of the first 24 hours

The team should continue from immediate containment into investigation, eradication and controlled recovery. The times below are targets, not a reason to rush an unsafe action.

Time / stage	Action	Owner	Required approval	Evidence to retain	Completion check
09:45–12:00 — Investigation	Build a timeline from E01–E08 and examine whether	Security Analyst and Forensics Specialist	Incident Response Lead	Timeline, relevant logs, interview	Findings distinguish confirmed

	the payroll attachment, account logins and upload are connected. Determine which systems and accounts show evidence of compromise.			notes and findings	observations from hypotheses and unresolved questions.
09:45–12:00 — Communication	Send an approved operational update to staff and learners using a trusted channel. State what is known about the service disruption and provide examination guidance without making unverified claims about data theft.	Communications Lead	Management, with legal/privacy advice where appropriate	Approved messages, recipients, times and channel used	Stakeholders receive accurate information and know where to obtain updates.
12:00–16:00 — Longer-term containment	Review privileged and cloud accounts, revoke suspicious sessions, reset affected credentials through a controlled process and strengthen access controls. Restrict network paths between affected and unaffected systems where needed.	IT Operations and Security Analyst	Incident Response Lead; system owner where required	Account and configuration changes, session records and approvals	Suspected access routes are restricted and the team has checked for other affected accounts.
12:00–18:00 — Eradication planning	Identify the likely entry point, malicious files, unauthorised access mechanisms and any persistence found during investigation. Prepare a clean rebuild or	Security Analyst and Forensics Specialist	Incident Response Lead and system owner	Investigation findings, identified artefacts and remediation plan	The team has documented what must be removed or corrected and how it will verify the result.

	remediation plan for affected systems.				
12:00–18:00 — Backup validation	Assess candidate backups in a controlled environment separated from affected production systems. Check their integrity, completeness, restore success and signs of compromise before approving their use.	IT Operations and Security Analyst	Designated restoration approver	Backup source, restore logs, validation results and any failures	A suitable recovery point is supported by documented checks; otherwise, recovery remains on hold pending another option.
16:00–22:00 — Controlled recovery	Rebuild or clean affected systems as appropriate, address the entry point, apply necessary updates and restore validated data into a controlled environment.	IT Operations	Designated restoration approver	Rebuild records, configuration checks and restore logs	Systems pass technical checks before being connected to production or opened to users.
18:00–08:45 next day — Monitor and reassess	Monitor security alerts, account activity, file changes, network traffic and backup activity for signs that the incident has returned. Continue investigating unresolved systems and possible data exposure.	Security Analyst and IT Operations	Incident Response Lead	Monitoring records, alerts, findings and updated timeline	No unexplained recurrence is observed during the agreed monitoring period, and remaining risks are documented.
By 08:45 next day — Review progress	Review the incident status, service restoration, outstanding risks and communication needs. Decide whether containment and recovery should continue or be escalated.	Incident Response Lead and Management / Business Continuity Lead	Management for major business decisions	Incident log, recovery status and decisions	A documented review identifies what has been completed, what remains open and who owns the next steps.

3.2 Difficult decisions and rationale

Decision 1: Containment versus evidence preservation

I would isolate FIN-PC07 promptly because the mass file changes suggest that malicious activity may still be occurring. Waiting too long to collect evidence could allow further damage or give the attacker more time to access other systems. However, isolating a device can interrupt active sessions and cause some volatile information to be lost.

Where practical, a trained responder should capture useful volatile evidence before isolation, provided this does not delay urgent containment. If immediate isolation is necessary, the team should proceed and document why it was necessary, what evidence may have been lost, who authorised the action, the time it occurred and any operational impact.

The same approach should be applied to FS01 and other systems if there is evidence of active compromise. Containment decisions should be based on the risk to the organisation, not on a blanket rule that every system must be disconnected immediately.

Decision 2: Restoring examination access when backup safety is uncertain

The examination scheduled for 11:00 makes recovery urgent, but I would not restore an unverified backup directly to production just to meet the deadline. A backup job reporting success does not prove that the data is clean or that the backup can be restored successfully. Since BAK01 may also be at risk, the team must establish whether the backup environment can be trusted.

I would ask IT Operations to assess the available recovery points and test a suitable backup in a controlled environment. The team should check that the restored files are complete, usable and free from signs of compromise. Management should receive an honest update on the likely recovery time and the risks involved.

If safe restoration cannot be completed before 11:00, management should consider postponing the examination or making another suitable arrangement for the learners. The decision and its reasons should be recorded. This approach balances business continuity with the need to protect the institute's data and avoid bringing the threat back into the environment.

3.3 Evidence register and chain of custody

The register below identifies evidence that the response team should collect. These are planned collection activities, not claims that the evidence has already been acquired. Use the actual collection date, time and results when the exercise or investigation reaches that stage.

Evidence ID	Source	Proposed collection method	Collector	Date and time (WAT, UTC+1)	Integrity check	Secure storage and custody
ER01	FIN-PC07 endpoint logs and relevant file artefacts	Export relevant security and system logs; collect identified artefacts using an approved method. Capture volatile evidence first only where practical and safe.	Forensics Specialist or trained designated responder	Planned — Day 0; record actual time of collection	Record the source and collection method. Calculate and record a cryptographic hash where appropriate and technically possible. No hash is available yet.	Store in restricted evidence storage. Record the collector, date, time and every transfer.
ER02	FS01 Windows logs, affected files and ransom note	Export relevant logs and securely collect copies of selected artefacts while avoiding unnecessary changes to the affected server.	Forensics Specialist	Planned — Day 0; record actual time of collection	Record filenames, source paths, acquisition method and applicable hashes. Do not assume the files are authentic or unaltered until checks are completed.	Store in restricted evidence storage, separate from normal shared folders. Maintain a custody record.
ER03	Microsoft 365 sign-in and audit records	Export available sign-in and audit records for the relevant account and time window.	Security Analyst	Planned — Day 0; record actual time of collection	Record the export time, account and date range, source and collection method. Verify file integrity where possible.	Restrict access to authorised responders and retain the original export securely.
ER04	Network records relating to the 1.2 GB upload	Collect available firewall, network, proxy or endpoint records that identify the	Security Analyst or authorised network administrator	Planned — Day 0; record actual time of collection	Record the log source, relevant time window, export method and integrity check performed.	Store securely with restricted access and document each custody transfer.

		destination and transfer details.				
ER05	BAK01 backup console, job records and candidate recovery points	Export backup job and access logs; record available recovery points and results from controlled restore testing.	IT Operations, with Security Analyst support	Planned — Day 0; record actual time of collection	Preserve the original records and document the validation method, test results and any errors. Calculate hashes where applicable.	Store the records and relevant copies in restricted evidence storage. Protect candidate backups from unauthorised changes.

Evidence handling and access restrictions

Only authorised responders should access collected evidence. Original evidence should be preserved, and analysis should be performed on copies where practical. Each item should have a unique ID, a record of its source, the person who collected it, the date and time, the method used, the integrity checks performed and its storage location.

Whenever evidence changes hands, the person releasing it and the person receiving it should record their names, the date and time, the reason for the transfer and the condition of the item. If a hash cannot be calculated, the team should record that limitation and use other appropriate integrity controls rather than inventing a hash or claiming that integrity has been verified.

The incident lead should periodically check that the evidence register is complete and that access to stored evidence remains restricted.

3.4 Eradication, restoration, and acceptance criteria

Removing the threat and preventing it from returning

Before restoring the affected systems, the team must establish how the attacker gained access and whether the threat remains active. The investigation should examine the payroll attachment opened on FIN-PC07, the unusual Microsoft 365 sign-in, the `svc_backup` administrator sessions and the 1.2 GB upload.

The team should remove identified malicious files and unauthorised access mechanisms, rebuild affected systems where necessary, apply security updates and address the likely entry point. Any accounts confirmed or reasonably suspected to be compromised should be secured. This may involve resetting

passwords, revoking active sessions, reviewing MFA settings and removing unnecessary administrator privileges.

The team should also check for wider compromise by reviewing authentication records, endpoint alerts, administrator activity, file changes and network connections across FIN-PC07, FS01, LMS01 and BAK01. Other accounts and systems should be examined if the evidence suggests that the attacker moved beyond the initially affected systems.

Restoration should only proceed when the team has sufficient evidence that the selected recovery environment is suitable. The fact that a system has been rebuilt or a backup has been restored does not, on its own, prove that the incident has been resolved.

Recommended restoration order and recovery targets

The targets below are proposed planning targets, not existing Northbridge service commitments. They should be confirmed with management and the relevant business owners.

Priority	System or activity	Recommended recovery target	Reason
1	Secure administrative access and recovery environment	Establish a trusted environment before restoring production services.	Recovery must not depend on accounts or systems that may still be compromised.
2	BAK01 and backup capability	Confirm a safe recovery source and reliable backup access before using it.	A compromised or unusable backup could prevent recovery or reintroduce the threat.
3	FS01 shared file server	Restore essential shared files from a verified recovery point after the server has been cleaned or rebuilt as necessary.	The learning portal depends on files stored on FS01, and staff also need access to shared information.
4	LMS01 learning portal	Aim to restore essential learning and assessment services within 8 hours of incident declaration, provided safe restoration is possible.	Learners need access to materials and assessments, and the scheduled examination is time-sensitive.
5	FIN-PC07 and finance operations	Rebuild or clean the workstation, secure relevant accounts and restore required files after validation.	The workstation requires investigation and must not be reconnected while it remains unsafe.

For planning purposes, the proposed recovery point objective (RPO) is no more than 24 hours of data loss for essential learning and assessment information. The proposed recovery time objective (RTO) for essential learning services is 8 hours. These targets must be validated with the business owner.

The last disconnected backup was made on Day −3 at 17:00. If no more recent backup can be verified as safe and usable, recovery from that point could mean losing up to several days of changes. The team must establish the actual recovery point and likely data loss before restoration. Any recovery point older than

the agreed RPO requires an explicit business decision and documented acceptance of the consequences; it should not be treated as automatically acceptable.

3.5 Recovery acceptance criteria

The institute should not declare the recovery complete simply because users can log in again. Before returning a service to normal use, the team should check that it is safe, functional and suitable for the business.

The following conditions should be met before the relevant business owner approves the return of a service:

1. **Threat addressed:** The identified entry point and known malicious activity have been addressed, and the team has checked for signs of persistence or further compromise.
2. **Accounts secured:** Suspected compromised accounts have been secured, unnecessary privileges have been removed, and relevant sessions and authentication settings have been reviewed.
3. **Backup validated:** The selected backup has been assessed for integrity, completeness, recoverability and signs of compromise. Any limitations or possible data loss have been documented.
4. **Service tested:** Restored systems and files work as expected. For LMS01, the team should test login, access to learning materials and assessment submission. For FS01, it should test access to required shared files.
5. **Security checks completed:** The team has reviewed relevant logs and monitoring alerts for signs of renewed malicious activity. Any outstanding risks have been documented and assessed.
6. **Business approval obtained:** The system owner confirms that the service meets operational needs, while the designated restoration approver confirms that the required technical checks have been completed.
7. **Monitoring arranged:** Enhanced monitoring remains in place after restoration, with a named owner responsible for reviewing alerts and escalating any recurrence.
8. **Records completed:** The team records the recovery point used, restoration time, validation results, decisions, outstanding issues and the person who approved the return to service.

The Incident Response Lead should coordinate the final review and recommend whether the incident can move towards closure. Management should approve formal closure after the response team has reviewed outstanding risks, confirmed the status of affected services and agreed on any remaining actions.

Task 4. Communication and escalation

4.1 Communication matrix

The incident may affect several groups, but they will not all need the same information. The response team should provide accurate updates, protect sensitive investigation details and use a trusted communication channel because corporate email has not yet been confirmed safe (E08). The teaching deck also stresses trusted communication channels, defined responsibilities and prepared notification procedures (ICDFA, n.d., slides 8 and 14).

Stakeholder group	Trigger for communication	Message owner	Approver	Channel	Update frequency
1. Management	Incident declared, major service disruption, significant new findings or decisions requiring approval.	Incident Response Lead	Senior management	Direct phone call or approved secure channel; email only when trusted.	Initial briefing, then every hour during the initial response and whenever a major decision is needed.
2. Learners	Learning materials or assessments become unavailable, or examination arrangements change.	Communications Lead	Management, with legal/privacy advice where needed	Official website or learning portal if trusted, SMS, or another verified channel.	Initial notice, updates when arrangements change, and a final notice when services or examination arrangements are confirmed.
3. IT and security staff	Incident activation, new evidence, containment actions, or changes to recovery priorities.	Incident Response Lead	Incident Response Lead	Staff phones and an approved secure communication channel.	Continuous coordination during active response, with formal updates at agreed intervals.

4. Learning portal or hosting provider	The portal is disrupted, technical support is required, or evidence suggests the provider's service may be involved.	IT Operations / System Owner	Incident Response Lead	Verified provider support contact or telephone.	Initial report, follow-up as findings emerge, and updates until the service issue is resolved.
5. Legal and privacy advisers	Possible unauthorised access to personal data, evidence of data exposure, or a potential reporting obligation.	Incident Response Lead	Management for significant legal or business decisions	Direct phone call or approved confidential channel.	As soon as the concern is identified, then whenever material evidence or a reporting deadline changes.
6. Staff and department heads	Systems are unavailable, staff need to change working arrangements, or normal procedures are suspended.	Communications Lead	Management	Phone, SMS or another verified staff communication channel.	Initial notice, followed by updates when staff actions or service availability change.
7. Relevant regulator or authority, if required	Legal/privacy advisers determine that a reporting obligation applies.	Legal / Privacy Adviser, supported by the designated reporting officer	Authorised management representative, according to policy	The authority's verified official reporting channel.	Within the applicable deadline, with further updates as required by the relevant rules.

The communication team should keep a record of the message, recipients, approval, channel and time sent. If corporate email is unsafe or unavailable, the team should use verified phone contacts or another approved secure channel rather than relying on the affected systems.

4.2 Executive briefing

To: Senior Management
From: Incident Response Lead
Time: Day 0, 09:45 WAT
Subject: Suspected ransomware incident and examination disruption

Northbridge is responding to a suspected ransomware incident affecting FIN-PC07 and FS01. Mass file changes, locked files and a ransom note have been reported (E06). Learners cannot open materials or submit assessments through the learning portal (E07).

The full scope remains unknown. Unusual Microsoft 365 and administrator logins (E02, E03) and a 1.2 GB upload to unfamiliar cloud storage (E04) require investigation. We have not confirmed data theft or established that the backup environment is safe. Successful backup job reports do not prove recoverability (E05).

The team is containing the suspected threat, preserving evidence, reviewing accounts and assessing recovery options. Management is asked to support containment and decide on an alternative examination arrangement if safe restoration cannot be completed before 11:00. An unverified backup must not be restored to production simply to meet the deadline.

The next update will be provided at 10:15 WAT, or earlier if a major finding requires a decision.

4.3 Learner notice (100–150 words)

Subject: Important update on the learning portal and examination

Dear Learners,

We are addressing a technical and cybersecurity incident affecting access to learning materials and assessment submissions on the institute’s learning portal.

Our team is investigating the issue and working to restore services safely. The full extent of the incident is still being assessed, and we will share verified information as it becomes available.

The 11:00 examination is under review. Please do not assume it is cancelled or will proceed until you receive an official update. Check the institute’s verified communication channels for instructions. If the portal remains unavailable, retain any work you have prepared and follow the next notice rather than repeatedly attempting submissions.

We apologise for the disruption. The next update will be provided by 10:15 WAT.

Thank you for your patience.

4.4 Legal and privacy notification assessment

The Legal / Privacy Adviser should work with the incident response team to determine whether the incident has resulted in a personal data breach or another event that must be reported. The unusual sign-in

and large data upload raise concerns, but they do not by themselves prove that learner information was stolen.

The adviser should establish what personal information may have been affected, whose information it relates to, whether unauthorised access or disclosure occurred, and what evidence supports the assessment. They should then identify the laws, regulatory requirements and contractual obligations that apply to the institute, including the jurisdiction in which it operates.

Based on this assessment, the adviser should confirm whether notification is required, which regulator or authority must be contacted, whether affected learners or staff must be informed, what information each notice must contain, and the applicable deadlines. The adviser should record the basis for the decision and ensure that any required notification is approved and submitted on time.

The assignment does not establish the institute's jurisdiction or confirm a personal data breach. Therefore, a specific legal deadline should not be assumed without checking the applicable law and authoritative guidance.

Operational notices about service disruption and examination arrangements should be issued promptly when needed. These notices are separate from formal breach notifications, which must follow the applicable legal requirements.

4.5 Escalation rules

The Incident Response Lead should escalate the incident to senior management when the incident causes significant disruption, appears to affect additional systems, raises serious concerns about sensitive data, or threatens the ability to restore services safely. Any evidence that BAK01 or other recovery systems have been compromised should also be escalated promptly.

Legal and privacy advisers should be involved as soon as possible if personal data may have been exposed. They should assess whether formal notification is required rather than waiting for the entire technical investigation to finish.

The Communications Lead should obtain approval before issuing public statements or major changes to examination arrangements. If corporate email is unavailable or cannot be trusted, the team should use verified phone contacts or another approved secure channel.

Where immediate action is needed to prevent further damage, authorised responders should not wait unnecessarily for routine approval. They must record the action taken, the reason, the person authorising it and any impact on business operations. Management should receive an update whenever a major decision is required or the risk assessment changes.

Task 5. Tabletop exercise and improvement plan

5.1 Exercise objectives

The aim of this 60-minute tabletop exercise is to test Northbridge Skills Institute's ability to respond to the suspected ransomware incident, make decisions under pressure and restore services safely.

The objectives are to:

1. Test how quickly the team can identify and agree on containment actions.
2. Test whether the team can preserve evidence and investigate the possible extent of the compromise.
3. Assess how the team handles the 11:00 examination when safe restoration is uncertain.
4. Test communication with management, learners and other relevant stakeholders.
5. Identify weaknesses in the response plan and agree on practical improvements.

5.2 Participants and roles

For this exercise, I will take each role individually and record how each participant would respond. In an actual incident, these responsibilities would be shared among the relevant staff.

Participant	Responsibility
Incident Response Lead	Coordinates the response, records decisions, assesses severity and escalates major issues.
Security Analyst	Investigates alerts, suspicious logins, file changes and the 1.2 GB upload.
IT Operations/System Owner	Isolates affected systems, checks backups and carries out approved recovery activities.
Forensics Specialist	Advises on evidence preservation and investigation methods.
Legal/Privacy Adviser	Assesses possible personal data exposure and applicable reporting obligations.
Communications Lead	Prepares approved updates for learners, staff and the media.
Management/Business Continuity Lead	Makes business decisions, approves examination arrangements and authorises restoration through the agreed process.

5.3 Exercise agenda

Exercise time	Activity
Minutes 0–10	Review the incident, confirm responsibilities and agree on immediate containment actions.
Minutes 10–20	Respond to management's request to reopen the learning portal.
Minutes 20–35	Investigate the attacker's claim and assess possible data exposure.
Minutes 35–45	Respond to the failed backup restoration and review recovery alternatives.
Minutes 45–55	Handle the social media post, journalist's enquiry and additional inject.
Minutes 55–60	Evaluate performance and agree on improvement actions.

5.4 Success criteria

The exercise will be assessed against these measurable criteria:

1. The team identifies immediate containment actions within the first 10 minutes.
2. The team does not approve production restoration from an unverified backup or an unreadable snapshot.
3. At least five decisions are recorded with an owner, rationale, communication action and expected effect.
4. The team identifies the evidence needed to investigate the possible exposure of learner information without treating the attacker's claim as proof.
5. The team identifies an authorised spokesperson and an alternative communication channel if corporate email cannot be trusted.
6. At least five improvement actions are assigned owners, target dates and measurable completion evidence.

5.5 Simulated exercise and responses

Note: All responses and results below are simulated for this assignment. They do not represent actions taken during a real incident.

Minute 0: Initial incident briefing

The exercise begins with the evidence already identified in Task 1. E06 records mass file changes on FIN-PC07 and locked files with a ransom note on FS01. E07 confirms that learners cannot access materials or submit assessments. E02, E03 and E04 raise further concerns, while E05 does not establish that the backups are safe to restore.

- **Incident Response Lead:** I would confirm the suspected ransomware incident, retain the initial High severity rating and open an incident log.
- **Security Analyst:** I would review the available alerts and authentication records to establish the likely scope.
- **IT Operations:** I would isolate FIN-PC07 and assess whether FS01 requires further isolation. I would also restrict suspicious privileged access in line with the incident procedure.
- **Management/Business Continuity Lead:** I would request an update on the examination and the available alternatives.

Simulated result: The team prioritises containment, evidence preservation and examination continuity.

Minute 10: Management requests that the portal be reopened

Management asks the team to reopen the learning portal before 11:00, even if the latest backup has not been verified.

- **Incident Response Lead:** I would explain that an unverified backup could reintroduce the threat or cause further damage. I would recommend controlled testing before any production restoration.
- **IT Operations:** I would assess available recovery points and determine whether a safe restoration test can be completed.
- **Management/Business Continuity Lead:** I would prepare an alternative examination arrangement if safe restoration cannot be completed in time.

Decision: Do not restore the portal from an unverified backup. Continue recovery checks and prepare an alternative examination arrangement.

Simulated result: The team avoids allowing examination pressure to override security and recovery requirements.

Minute 20: Attacker claims to hold all 1,800 learner records

The attacker threatens to publish the records within 12 hours and provides a screenshot whose authenticity is unknown.

- **Security Analyst:** I would preserve the screenshot and investigate the claim alongside the 1.2 GB upload in E04.
- **Forensics Specialist:** I would advise that the screenshot and related evidence be preserved and examined before conclusions are drawn.
- **Legal/Privacy Adviser:** I would begin assessing possible personal data exposure and identify applicable reporting obligations.
- **Communications Lead:** I would prepare a holding statement but would not confirm that learner records had been stolen without supporting evidence.

Decision: Investigate the claim urgently, preserve evidence and avoid unsupported statements about data theft.

Simulated result: The team recognises the seriousness of the allegation without treating it as confirmed.

Minute 35: The latest network backup fails restoration

A test restoration fails because the snapshot is unreadable.

- **IT Operations:** I would record the error, stop relying on that snapshot and assess other recovery points, including the last disconnected backup from Day −3 at 17:00.
- **Security Analyst:** I would investigate whether BAK01 or the `svc_backup` account may have been affected, considering the unusual logins in E03.
- **Incident Response Lead:** I would update management and revise the recovery plan.
- **Management/Business Continuity Lead:** I would approve alternative examination arrangements if no safe recovery option is available before 11:00.

Decision: Reject the unreadable snapshot for restoration and assess other backups in a controlled environment.

Simulated result: Recovery may be delayed, but the team avoids introducing a potentially compromised backup into production.

Minute 45: Social media post and journalist's enquiry

A social media post claims the examination has been cancelled, and a journalist asks whether learner information has been exposed.

- **Communications Lead:** I would verify the examination status with management and prepare an approved update for learners and the public.
- **Incident Response Lead:** I would provide confirmed facts and clearly identify what remains unknown.
- **Legal/Privacy Adviser:** I would review statements about possible data exposure and advise on applicable notification obligations.
- **Management/Business Continuity Lead:** I would approve the official examination update.

Decision: Issue a factual update through a verified channel, using the Communications Lead as the message owner and the authorised management representative as approver.

Simulated result: Learners receive clear information, and the institute avoids making unverified claims about data exposure.

Minute 50: Additional inject — new suspicious administrator logins

The facilitator introduces a new development: unusual administrator logins are detected on another server while containment is underway.

- **Security Analyst:** I would investigate the login records and identify the account, source and activities involved.
- **IT Operations:** I would restrict the affected account or isolate the server where justified, following the incident procedure.
- **Forensics Specialist:** I would advise on preserving relevant logs and other available evidence.

- **Incident Response Lead:** I would reassess the incident scope and severity, escalating to Critical if the new evidence meets the criteria established in Task 1.
- **Management/Business Continuity Lead:** I would consider the effect on recovery timelines and essential services.

Decision: Expand the investigation and containment to the additional server, preserve evidence and reassess severity.

Simulated result: The team recognises that the incident may extend beyond FIN-PC07 and FS01 and adjusts the response accordingly.

5.6 Simulated decision log

Inject/event	Decision	Decision owner	Rationale	Communication	Effect on response or recovery
Initial incident briefing	Declare a suspected ransomware incident and isolate FIN-PC07.	Incident Response Lead	E06 provides strong evidence of ransomware activity.	Notify management and the response team through verified channels.	Starts coordinated containment and investigation.
Minute 10: Pressure to reopen the portal	Reject restoration from an unverified backup and prepare an alternative examination arrangement.	Management/Business Continuity Lead, informed by technical advice from the Incident Response Lead	Unsafe restoration could worsen the incident or cause further data loss.	Explain the risk to management and prepare a learner update.	Safe recovery takes priority over meeting the original examination time.
Minute 20: Attacker's data claim	Preserve the screenshot and investigate the claim and possible data exposure.	Incident Response Lead	The claim is unverified and must be checked against available evidence.	Involve the Legal/Privacy Adviser and Communications Lead.	Expands the investigation and begins assessment of reporting obligations.
Minute 35: Unreadable backup	Reject the failed snapshot and assess other recovery points.	IT Operations/System Owner	The snapshot cannot currently provide a usable recovery option.	Inform the Incident Response Lead and management of the delay.	Recovery options are reassessed and the examination contingency may be required.

Minute 45: Public enquiries	Issue an approved factual update without claiming that data was stolen.	Management/Business Continuity Lead	Public statements must be accurate and consistent with confirmed findings.	Communications Lead uses a verified channel and approved wording.	Reduces confusion and avoids unsupported public claims.
Minute 50: New administrator logins	Expand containment and investigation and reassess severity.	Incident Response Lead	New suspicious activity may indicate wider compromise.	Notify Security, IT Operations and management.	Scope expands and recovery may be delayed until the additional risk is assessed.

5.7 Evaluation of the simulated results

Success criterion	Simulated result	Assessment
Identify containment actions within 10 minutes	The team prioritised isolating FIN-PC07 and reviewing suspicious privileged access.	Met in the simulation.
Avoid unsafe restoration	The team rejected the unverified backup and unreadable snapshot.	Met in the simulation.
Record at least five decisions	Six decisions were documented with owners, reasons and communication actions.	Met in the simulation.
Investigate possible data exposure	The team preserved the screenshot and identified further investigation of E04 as necessary.	Met in the simulation; the claim remains unverified.
Use approved communication arrangements	The team identified a message owner, an approver and verified communication channels.	Met in the simulation.
Assign improvement actions	The improvement plan below assigns owners, deadlines and completion evidence.	Planned; completion still needs to be verified.

The exercise suggests that the plan provides a clear structure for coordinating the response. However, the failed backup restoration highlights the need for more reliable recovery testing, while the additional administrator activity shows the importance of monitoring for wider compromise. These are simulated findings and would need to be validated through actual exercises or incident experience. This reflects the teaching deck's emphasis on documenting lessons learned and using them to improve the response plan (ICDFA, n.d., slides 12–13).

5.8 Improvement plan

Improvement action	Priority	Owner	Target completion	Measurable evidence of completion

Test protected and disconnected backups, including restoration and integrity checks.	Critical	IT Operations/System Owner	Within 14 days	A documented restoration test succeeds, with integrity results and recovery time recorded.
Review `svc_backup` privileges and restrict access to the minimum necessary.	Critical	IT Operations and Security Analyst	Within 7 days	Access review is completed, unnecessary privileges are removed and changes are verified.
Maintain an offline incident contact list, including service provider contacts.	High	Incident Response Lead	Within 5 days	Updated offline contact list is available and a contact test is recorded.
Establish an approved alternative communication process if corporate email or the portal cannot be trusted.	High	Communications Lead	Within 10 days	A test message is sent through the approved alternative channel and the result is documented.
Improve monitoring for unusual administrator logins, mass file changes and suspicious transfers.	High	Security Analyst	Within 30 days	Test events generate alerts and the results are documented.
Conduct a follow-up tabletop exercise using the identified weaknesses.	Medium	Incident Response Lead	Within 30 days	A report records performance against the success criteria and tracks outstanding actions.

The deadlines above are proposed targets and should be confirmed by management based on available staff and resources.

5.9 Post-incident review and closure

I would schedule a post-incident review within five working days after the incident has been contained and essential services have been safely restored. The review would examine the incident timeline, confirmed scope, root cause where established, evidence handling, decisions, communications, recovery performance and lessons learned.

The Incident Response Lead would coordinate the review and recommend closure. Management, acting as the designated closure authority, would approve formal closure after confirming that containment and recovery criteria have been met, evidence is secured, required reporting and communication actions have been addressed, and outstanding improvements have assigned owners and deadlines.

Any unresolved high-risk issue must be documented and escalated for an explicit management decision; it should not simply be marked as completed. The final review findings would be used to update the incident response plan and verify that the agreed improvements are completed.

Task 6. Case study analysis and critical reflection

The healthcare ransomware case on slide 16 of the teaching deck describes a 2,500-employee organisation attacked through a phishing email with a malicious attachment. The malware moved across the network for 72 hours before encryption began. The incident was detected on Day 4, critical systems were restored within 72 hours, and full restoration took seven days (ICDFA, n.d., slide 16).

Three response strengths stand out. First, offline backups allowed recovery without paying the ransom. Second, network segmentation limited the spread of ransomware. Third, the organisation had an established incident response team and playbooks, which supported prompt containment and coordinated recovery. It also completed regulatory notifications on time.

However, the attacker remained undetected for 72 hours, giving the malware time to move across the network. Earlier detection could have reduced this opportunity. The slide also reports no patient data exfiltration without explaining the evidence behind that conclusion. It notes that backup testing revealed restoration gaps, showing that backups must be tested.

I would transfer two lessons to Northbridge. First, I would prioritise regular restoration tests. This addresses E05, where successful backup jobs do not prove that data is safe or recoverable, and the tabletop exercise, where the latest network backup produced an unreadable snapshot. Second, I would strengthen server monitoring and network segmentation to detect unusual administrator activity and limit ransomware spread, particularly given the `svc_backup` logins in E03.

Restoring critical systems within 72 hours is not the same as restoring every system within seven days. Critical systems are prioritised to resume essential operations. Full restoration can take longer because additional systems must be rebuilt, data integrity checked, security controls verified and services tested before normal operations resume.

Before concluding that no patient data was stolen, investigators would need to examine endpoint, server, identity and network logs, outbound transfer records, accessible files and evidence of what the attacker could access. They should look for signs of data leaving the organisation and document the limits of the evidence. The absence of an alert alone does not prove that no data was stolen.

After the tabletop exercise, I would revise my recovery decision to require a verified and successfully tested backup before production restoration, while management prepares an alternative examination arrangement if safe restoration cannot be completed in time. This balances service continuity with the need to avoid reintroducing the threat.

References

Cybersecurity and Infrastructure Security Agency (CISA), Federal Bureau of Investigation (FBI), National Security Agency (NSA), & Multi-State Information Sharing and Analysis Center (MS-ISAC). (2023). #StopRansomware guide. https://www.cisa.gov/resources-tools/resources/stopransomware-guide

International Cybersecurity and Digital Forensics Academy (ICDFA). (n.d.). *Incident response planning* [GRC105 Week 20 teaching slides]. Incident Management and Business Continuity module.

Nelson, A., Rekhi, S., Scarfone, K., & Souppaya, M. (2025). *Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile* (NIST Special Publication 800-61 Rev. 3). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-61r3

National Institute of Standards and Technology (NIST). (n.d.). *Incident response project*. https://csrc.nist.gov/projects/incident-response